

(Vulnerability Assessment and Penetration Testing)

What is VAPT?

- Vulnerability Assessment and Penetration Testing (VAPT) are two types of vulnerability testing. The tests have different strengths and are often combined to achieve a more complete vulnerability analysis.
- In short, Penetration Testing and Vulnerability Assessments perform two different tasks, usually with different results, within the same area of focus.

What Is a Vulnerability Assessment?

- Vulnerability Assessment is known as Vulnerability Testing, is a software testing type performed to evaluate the security risks in the software system in order to reduce the probability of a threat.
- A vulnerability is any mistakes or weakness in the system security procedures, design, implementation or any internal control that may result in the violation of the system's security policy.
- In other words, the possibility for intruders (hackers) to get unauthorized access.
- Vulnerability testing helps organizations identify vulnerabilities in their software and supporting infrastructure before a compromise can take place.

Importance of vulnerability assessments

- A vulnerability assessment provides an organization with information on the security weaknesses in its environment and provides direction on how to assess the risks associated with those weaknesses and evolving threats. This process offers the organization a better understanding of its assets, security flaws and overall risk, reducing the likelihood that a cybercriminal will breach its systems and catch the business off guard.

How does a vulnerability assessment work?

- There are three primary objectives of a vulnerability assessment.
- Identify vulnerabilities ranging from critical design flaws to simple misconfigurations.
- Document the vulnerabilities so that developers can easily identify and reproduce the findings.
- Create guidance to assist developers with remediating the identified vulnerabilities.
- Vulnerability testing can take various forms. One method is Dynamic Application Security Testing ([DAST](#)). A dynamic analysis testing technique that involves executing an application (most commonly a Web application), DAST is performed specifically to identify security defects by providing inputs or other failure conditions to find defects in real time. Conversely, Static Application Security Testing ([SAST](#)) is the analysis of an application's source code or object code in order to identify vulnerabilities *without* running the program.

How does a vulnerability assessment work?

Cont'd

- The two methodologies approach applications very differently. They are most effective at different phases of the software development life cycle (SDLC) and find different types of vulnerabilities. For example, SAST detects critical vulnerabilities such as [cross-site scripting](#) (XSS) and [SQL injection](#) earlier in the SDLC. DAST, on the other hand, uses an outside-in [penetration testing](#) approach to identify security vulnerabilities while Web applications are running.
- Another method of vulnerability assessment in and of itself, penetration testing entails goal-oriented security testing. Emphasizing an adversarial approach (simulating an attacker's methods), penetration testing pursues one or more specific objectives (e.g., [capture the flag](#)).

Types of Vulnerability Assessments

Vulnerability assessments depend on discovering different types of system or network vulnerabilities, which means the assessment process includes using a variety of tools, scanners and methodologies to identify vulnerabilities, threats and risks.

- Network-based scans
- Host-based scans (i.e., system-configuration reviews)
- Wireless scans
- Application scans (included within penetration testing)
- Database scans

Network-based scans

- Network-based scans are used to identify possible network security attacks. This type of scan can also detect vulnerable systems on wired or wireless networks.
- A network vulnerability assessment is the process of reviewing and analyzing a computer network for possible security vulnerabilities and loopholes.
- It is used by network administrators to evaluate the security architecture and defense of a network against possible vulnerabilities and threats.
- A network-based scanner is usually installed on a single machine that scans a number of other hosts on the network. It helps detect critical vulnerabilities such as mis-configured firewalls, vulnerable web servers, risks associated with vendor-supplied software, and risks associated with network and systems administration.

Network-based scans

- A network vulnerability assessment is a broad process that includes tasks such as:
- Security control check
- Identifying, quantifying and prioritizing network threats
- Router/Wi-Fi password analysis
- Reviewing network strength against network-based attacks such as:
- Distributed denial of service (DDoS)
- Man-in-the-middle attack (MITM)
- Network intrusion
- Device-level security analysis (router, switch, computer)

Host-Based Scans

- Host-based scans are used to locate and identify vulnerabilities in servers, workstations or other network hosts. This type of scan usually examines ports and services that may also be visible to network-based scans, but it offers greater visibility into the configuration settings and patch history of scanned systems.
- The assessment of critical servers, which may be vulnerable to attacks if not adequately tested or not generated from a tested machine image.

Wireless Network Scans

- Wireless network scans of an organization's Wi-Fi networks usually focus on points of attack in the wireless network infrastructure. In addition to identifying rogue [access points](#), a wireless network scan can also validate that a company's network is securely configured.

Application Scans

- Application scans can be used to test websites in order to detect known software vulnerabilities and erroneous configurations in network or web applications.
- Web Application Scanners that assess the security aspects of web applications (such as cross site scripting and SQL injection) running on web servers. It should be noted that web application scanners cannot provide comprehensive security checks on every aspect of a target web application. Additional manual checking (such as whether a login account is locked after a number of invalid login attempts) might be needed in order to supplement the testing of web applications.

Database scans

- Database scans can be used to identify the weak points in a database so as to prevent malicious attacks, such as SQL injection attacks.
- The assessment of databases or big data systems for vulnerabilities and misconfigurations, identifying rogue databases or insecure dev/test environments, and classifying sensitive data across an organization's infrastructure.

BENEFITS OF VULNERABILITY SCANNERS

- **Firstly, a vulnerability scanner** allows early detection and handling of known security problems. By employing ongoing security assessments using vulnerability scanners, it is easy to identify security vulnerabilities that may be present in the network, from both the internal and external perspective.
- **Secondly, a new device or even a new system** may be connected to the network without authorization. A vulnerability scanner can help identify rogue machines, which might endanger overall system and network security.
- **Thirdly, a vulnerability scanner helps** to verify the inventory of all devices on the network. The inventory includes the device type, operating system version and patch level, hardware configurations and other relevant system information. This information is useful in security management and tracking.

LIMITATIONS OF VULNERABILITY SCANNERS

- The drawbacks of vulnerability scanners are:
 1. **Snapshot only:** a vulnerability scanner can only assess a "snapshot of time" in terms of a system or network's security status. Therefore, scanning needs to be conducted regularly, as new vulnerabilities can emerge, or system configuration changes can introduce new security holes.
 2. **Human judgment is needed:** Vulnerability scanners can only report vulnerabilities according to the plug-ins installed in the scan database. They cannot determine whether the response is a false negative or a false positive. Human judgment is always needed in analyzing the data after the scanning process.

Vulnerability assessment: Security scanning process

- 1. Vulnerability identification (testing)
- 2. Vulnerability analysis
- 3. Risk assessment
- 4. Remediation



Vulnerability assessment cannot be a one-off activity. To be effective, organizations must operationalize this process and repeat it at regular intervals.

Vulnerability identification (testing)

- The objective of this step is to draft a comprehensive list of an application's vulnerabilities. Security analysts test the security health of applications, servers or other systems by scanning them with automated tools, or testing and evaluating them manually. Analysts also rely on vulnerability databases, vendor vulnerability announcements, asset management systems and threat intelligence feeds to identify security weaknesses.

Vulnerability analysis

- The objective of this step is to identify the source and root cause of the vulnerabilities identified in step one.
- It involves the identification of system components responsible for each vulnerability, and the root cause of the vulnerability. For example, the root cause of a vulnerability could be an old version of an open source library. This provides a clear path for remediation – upgrading the library.

Risk assessment

- The objective of this step is the prioritizing of vulnerabilities. It involves security analysts assigning a rank or severity score to each vulnerability, based on such factors as:
 - Which systems are affected.
 - What data is at risk.
 - Which business functions are at risk.
 - Ease of attack or compromise.
 - Severity of an attack.
 - Potential damage as a result of the vulnerability.
 -

4. Remediation

- The objective of this step is the closing of security gaps. It's typically a joint effort by security staff, development and operations teams, who determine the most effective path for remediation or mitigation of each vulnerability.
- Specific remediation steps might include:
- Introduction of new security procedures, measures or tools.
- The updating of operational or configuration changes.
- Development and implementation of a vulnerability patch.